



AUDIT DOMAIN

DOMAIN-01

NETWORK SEGMENTATION & ISOLATION

FOCUS: How well is network divided into protected segments?

CRITICAL FOR: Preventing lateral movement

REGULATORY REFERENCES: PCI-DSS (network segmentation), NIST (zero trust)

WHAT'S ASSESSED

Is network flat (1 segment) or segmented (multiple segments)?; Are sensitive systems isolated (DMZ, database segment, admin segment)?; Are firewall rules enforced between segments?; Is network architecture documented?; Are VLANs/subnets properly configured?

TYPICAL FINDINGS

Critical (1-2 star): Flat network, no segmentation, everything can talk to everything; Major (2-3 star): Basic segmentation exists, but enforcement is weak; Minor (3-4 star): Segmentation exists, few rule violations; Compliant (4-5 star): Strong segmentation, zero-trust architecture;

REAL-WORLD QUESTION

"If one system is compromised, how far can the attacker spread?" Flat network: Entire organization immediately; 3-zone network: Blocked by firewalls; Zero-trust: Individual systems isolated;

AUDIT EVIDENCE

Network diagram (shows segments); Firewall rule documentation; Network ACL lists; Proof of implementation (switch configs); Test results (can systems cross segments? No);

COMPLIANCE STANDARDS

PCI-DSS Requirement 1: Network segmentation for cardholder data; NIST CSF: PR.AC-5 (Network integrity protected via segmentation); CIS Control 12: Network Infrastructure Management (v8);

REMEDIATION ACTIONS

✓ Implement network segmentation (ARCH-02, ARCH-03 in Network Building); ✓ Deploy firewall with segmentation rules (SEC-08); ✓ Implement zero-trust architecture (ARCH-03); ✓ Test segmentation enforcement;

IMPACT IF FAILED (1-2 STARS)

T-04 (Lateral Movement) becomes trivial for attackers; Incident Response: -1 to NETWORK defenses (canonical modifier); Disaster Recovery: -10 DR budget penalty (attacker spreads widely);

INCIDENT ZERO - AUDIT & COMPLIANCE



AUDIT DOMAIN

DOMAIN-02

ACCESS CONTROL & IDENTITY MANAGEMENT

FOCUS: How are user identities managed and access controlled?

CRITICAL FOR: Preventing unauthorized access

REGULATORY REFERENCES: HIPAA (access controls), GDPR (access management)

WHAT'S ASSESSED

Is there centralized identity management (Domain Controller/Azure AD)?; Is multi-factor authentication (MFA) enabled for sensitive access?; Are access permissions based on least privilege?; Are access reviews performed (verify who has access)?; Are privileged accounts managed (admin accounts, service accounts)?;

TYPICAL FINDINGS

Critical (1-2 star): No centralized identity, weak passwords, no MFA; Major (2-3 star): Some identity management, MFA not universal; Minor (3-4 star): Good identity management, minor gaps; Compliant (4-5 star): Strong identity, MFA everywhere, privilege management;

REAL-WORLD QUESTION

"How easily can an attacker use stolen credentials?" Weak: No MFA, can use stolen password immediately; Medium: MFA only for some systems; Strong: MFA everywhere, weak credentials are useless;

AUDIT EVIDENCE

AD/directory configuration; MFA enrollment status; Access policy documentation; Privileged account audit (who has admin?); Account review records (periodic access verification);

COMPLIANCE STANDARDS

PCI-DSS Requirement 8: User identification and authentication; HIPAA Rule 164.308(a)(4): Unique user identification; NIST CSF: PR.AC-1 (Physical & logical access controls);

REMEDIATION ACTIONS

✓ Deploy MFA (D-07 in Hardening); ✓ Implement password vault (D-12); ✓ Credential Guard for privileged access (D-16); ✓ Access reviews quarterly;

IMPACT IF FAILED (1-2 STARS)

T-03 (Compromised Credentials), T-06 (Minikatz) become likely; Incident Response: -1 to CREDENTIAL_ABUSE defenses (canonical modifier); Disaster Recovery: -15 DR budget penalty (attacker can restore themselves with stolen creds);

INCIDENT ZERO - AUDIT & COMPLIANCE



AUDIT DOMAIN

DOMAIN-03

THREAT DETECTION & INCIDENT RESPONSE

FOCUS: Can the organization detect and respond to attacks?

CRITICAL FOR: Finding breaches quickly

REGULATORY REFERENCES: GDPR (breach detection), HIPAA (log monitoring)

OPTIONAL (V2.2): A 5-star rating in this domain grants +1 to Incident Response investigation rolls if IR is played later.

WHAT'S ASSESSED

Are logs being collected centrally (SIEM or similar)?; Is there 24/7 monitoring of critical systems?; Are alerts configured to detect suspicious activity?; Is there incident response plan documented?; Are incident responders trained?;

TYPICAL FINDINGS

Critical (1-2 star): No logging, no monitoring, no incident response plan; Major (2-3 star): Some logging, limited monitoring; Minor (3-4 star): Good logging, some gaps in alerting; Compliant (4-5 star): Comprehensive logging, active monitoring, trained team;

REAL-WORLD QUESTION

"How quickly will you detect an active attacker?" Poor: Days/weeks (after data is already stolen); Medium: Hours (after attacker has spread); Strong: Minutes (catch attacker early);

AUDIT EVIDENCE

SIEM/logging configuration; Alert rules documentation; Incident response plan; Training records (who's trained?); Incident history (how did you detect past incidents?);

COMPLIANCE STANDARDS

GDPR Article 33: Breach notification timing (72 hours); HIPAA Rule 164.308(a)(6): Incident response procedures; NIST CSF: DE.AE-3 (Event detection processes);

REMEDIATION ACTIONS

✓ Deploy SIEM (D-09, D-22); ✓ Configure log centralization (D-05); ✓ Create SIEM correlation rules (D-10); ✓ Threat hunting program (D-13);

IMPACT IF FAILED (1-2 STARS)

Breach detection is late (attacker has time to steal data); Incident Response: -1 to Investigation rolls (canonical modifier); late detection); Disaster Recovery: -10 DR budget penalty (dwell time longer; more data stolen);

INCIDENT ZERO - AUDIT & COMPLIANCE



AUDIT DOMAIN

DOMAIN-04

BACKUP & DISASTER RECOVERY

FOCUS: Can the organization recover from attacks/disasters?

CRITICAL FOR: Ransomware resilience

REGULATORY REFERENCES: Most breach laws mention recovery

WHAT'S ASSESSED

Is there a documented backup strategy (frequency, retention)?; Are backups tested regularly (restore actually works)?; Is backup storage off-site (geographically separated)?; Are backups immutable (cannot be deleted/encrypted)?; Is recovery time objective (RTO) documented for each system?;

TYPICAL FINDINGS

Critical (1-2 star): No backups or untested backups (may not restore); Major (2-3 star): Backups exist but not properly tested; Minor (3-4 star): Backups exist and tested, gaps in immutability; Compliant (4-5 star): 3-2-1 strategy, tested, immutable, offsite;

REAL-WORLD QUESTION

"Can you recover from ransomware?" Poor: No (backups are encrypted too); Medium: Yes but slowly (days to recover); Strong: Yes quickly (hours to recover, immutable backups);

AUDIT EVIDENCE

Backup schedule/documentation; Backup test results (prove restore works); Off-site backup location documentation; Immutable backup configuration; Recovery time estimates;

COMPLIANCE STANDARDS

Most breach laws assume backups exist (no recovery = massive damage); HIPAA Rule 164.308(a)(7): Data backup procedures; NIST CSF: PR.IP-4 (Resilience practices documented);

REMEDIATION ACTIONS

✓ Implement 3-2-1 backup strategy (D-19); ✓ Test backups quarterly (prove restore works); ✓ Immutable storage (WORM, cloud versioning); ✓ Off-site backup location;

IMPACT IF FAILED (1-2 STARS)

Ransomware attacks cannot be recovered from; Disaster Recovery: -25 DR budget penalty (no recovery option; expensive rebuild); Business interruption is long (days vs hours); No IR effect (matters in Disaster Recovery);

INCIDENT ZERO - AUDIT & COMPLIANCE



AUDIT DOMAIN

DOMAIN-05

THIRD-PARTY RISK & CLOUD SECURITY

FOCUS: How well are vendors and cloud services managed?

CRITICAL FOR: Managing supply chain risk

REGULATORY REFERENCES: GDPR (processor accountability), PCI-DSS (vendor security)

WHAT'S ASSESSED

Is there a vendor management program?; Are vendors required to meet security standards?; Are vendor assessments conducted (security questionnaires, audits)?; Are cloud configurations secured (IAM, encryption, monitoring)?; Is data residency managed (where is customer data stored)?;

TYPICAL FINDINGS

Critical (1-2 star): No vendor management, cloud misconfigured; Major (2-3 star): Basic vendor management, cloud gaps; Minor (3-4 star): Vendor management exists, minor gaps; Compliant (4-5 star): Strong vendor program, cloud security;

REAL-WORLD QUESTION

"Is your vendor secure?" Poor: No idea (never asked them); Medium: They said they're secure (took their word); Strong: Assessed and monitored (ongoing verification);

AUDIT EVIDENCE

Vendor management policy; Vendor security questionnaires; Cloud configuration documentation; IAM policies for cloud access; Data residency mapping;

COMPLIANCE STANDARDS

GDPR Article 28: Processor agreements (vendor security required); PCI-DSS Requirement 12.8: Service provider agreements; NIST CSF: ID.SC (Supply Chain Risk Management);

REMEDIATION ACTIONS

✓ Vendor management program (SAs, security requirements); ✓ Cloud security posture management (CSPM tools); ✓ Cloud IAM hardening (least privilege); ✓ Regular vendor assessments;

IMPACT IF FAILED (1-2 STARS)

SCENARIO-03 (Supply Chain Compromise) becomes likely in Disaster Recovery; Vendor breach affects your customers; Liability disputes (who's responsible?); Incident Response: -1 to WEB_EXPLOIT defenses (canonical modifier); Disaster Recovery: -20 DR budget penalty (cloud provider recovery needed);

INCIDENT ZERO - AUDIT & COMPLIANCE



AUDIT DOMAIN

DOMAIN-06

SECURITY OPERATIONS & MONITORING

FOCUS: How is security operationalized (day-to-day)?

CRITICAL FOR: Sustained security posture

REGULATORY REFERENCES: Most frameworks mention continuous monitoring

WHAT'S ASSESSED

Is there a dedicated security team (CISO, analysts)?; Are security meetings held regularly?; Is vulnerability scanning done regularly?; Are patches applied timely?; Is security training conducted?;

TYPICAL FINDINGS

Critical (1-2 star): No security team, no updates, no training; Major (2-3 star): Small security team, infrequent patching; Minor (3-4 star): Security team exists, good operations; Compliant (4-5 star): Mature security operations, continuous improvement;

REAL-WORLD QUESTION

"Is security a priority for the organization?" Poor: No dedicated resources; Medium: Part-time effort; Strong: Dedicated team, empowered leadership;

AUDIT EVIDENCE

Org chart (is CISO position filled?); Security meeting minutes; Vulnerability scan reports; Patch management records; Training records;

COMPLIANCE STANDARDS

Most frameworks require security leadership; NIST CSF: PR.IP-1 (Security policy established & communicated); CIS Control 17: Incident Response Management (v8);

REMEDIATION ACTIONS

✓ Hire CISO (if missing); ✓ Establish security team; ✓ Regular vulnerability scanning; ✓ Patch management program; ✓ Security awareness training;

IMPACT IF FAILED (1-2 STARS)

Security functions are reactive (not proactive); Incident Response: -1 to Investigation rolls (canonical modifier); Disaster Recovery: -5 DR budget penalty (forensic investigation slow); Vulnerabilities accumulate (PT-10 Zero-Day risk increases);

INCIDENT ZERO - AUDIT & COMPLIANCE

